

Operation — Ghost Session

valid-session abuse across cloud + internal resources · Ref SSOU-WR-2026-1008-GS · LAB ONLY ·
TLP:AMBER

CONTAIN

IR decision

5 / 5

trust dimensions failed

10:39

pivot: 1 token, 2
countries

412 files

Treasury share read

EDR clean

no malware on
endpoint

20/20

tests pass

Thesis: The attacker never "broke in" — they were *let in as the user*. One already-authenticated session context was used from a second environment: no password event, no MFA prompt, no malware, EDR clean. The session failed all five trust dimensions — **Device + Location + Time + Behaviour + Resource** — and the event that ends the debate is one token appearing in two countries 18 minutes apart while the owner's laptop was still working. **Authenticate the session, not just the login.**

Mission 01 — Hybrid Identity Attack Surface Map

Asset	Role	Trust zone	Authentication	Access	Security gap	Detection source
IDP-01	Identity provider, SSO, token issuer	Identity (Tier 0)	Password + push MFA; 24 h sessions	every cloud app, RA gateway	no device binding; MFA claim inherited by new sessions; no re-prompt on new device	IdP sign-in + audit logs → SIEM-01
MFA service	Second factor	Identity	Push approval	all interactive sign-ins	phishable factor; protects sign-in only, not session reuse	MFA event log
RA-GW-01	Remote-access gateway	Perimeter / DMZ	SSO via IDP-01	VPN pool → internal subnets incl. finance servers	legacy profile skips device posture; flat reach to file servers	gateway logs, firewall, NetFlow
corp-cloud.lab tenant	Email, files, SaaS, admin console	Cloud	SSO tokens	per-app; console visible to every user	console reachable by standard users; no per-app conditional access	cloud audit log
FinLedger (browser app)	Finance SaaS	Cloud	SSO	finance staff	long-lived browser session	cloud audit, proxy
OAuth applications	Third-party / lab apps	Cloud	delegated consent	whatever the user grants	users can grant mail scopes + <code>offline_access</code> without review	app-consent audit
FS-FIN-01 / FS-FIN-02	Finance file servers (Reports / Treasury)	Internal — restricted	Kerberos / NTLM	finance groups	finance.manager can read Treasury (broader than the role needs); NTLM allowed	4624/5145, Zeek SMB
finance.manager	Standard user (high-value data)	User	SSO + MFA	FinLedger, FS-FIN-01, (FS-FIN-02)	excessive file permissions; session never revalidated	UEBA baseline
Privileged accounts	Cloud + AD admins	Tier 0	SSO + MFA	everything	standing admin (no just-in-time)	PIM / audit
Service accounts	App-to-app, backups	Internal	static secrets	file servers	long-lived secrets, no owner review	4624 Type 3/5, secret-age report
FIN-LT-22	Managed laptop	Endpoint	device cert + user	user's apps	browser holds the live session	EDR, proxy, DNS
SIEM-01 / EDR	Monitoring	Security	—	ingest	identity + cloud logs collected but not correlated with endpoint ; EDR blind to cloud-side session use	—

Mapped from lab configuration and the synthetic export only; nothing was scanned or tested.

Mission 02 — Attack-path hypotheses (conceptual, with ATT&CK + detection)

H1 — Valid session abuse

- **ATT&CK:** T1078 Valid Accounts · T1550.004 Use Alternate Authentication Material: Web Session Cookie (lab: simulated by a second log source re-using a session label — no theft performed or described).
- **Attacker objective:** act as the user without triggering a password or MFA event.
- **Authentication events expected:** *none new* — that is the signal. One interactive sign-in at 10:02, then a `session_created` at 10:07 with MFA "inherited".

- **Session telemetry expected:** same identity, new session ID, unregistered device, different IP/ASN, later a second country on the same token.
- **Cloud activity expected:** apps the owner never opens; activity while the owner's own session continues normally.
- **Indicators:** two live sessions on different devices; token reuse across geographies; activity after the owner signs out.
- **Detection opportunities:** token-to-device binding failures; "new session without MFA on unmanaged device"; one token / two countries; cloud event with no matching endpoint request.
- **Blue-team hunt:** for each identity, list sessions per day → flag any session whose device is not the user's managed device → compare its apps/resources with the 30-day baseline.

How can defenders tell whether a legitimate session is used by its owner? By checking the session continuously against five things the owner cannot easily fake and the attacker cannot easily copy all at once: **Device** (managed, compliant, same device ID as sign-in?) · **Location** (same network/ASN; can one token be in two places?) · **Time** (inside the user's working pattern; still alive after sign-out?) · **Behaviour** (same apps, same volume, same pace as baseline?) · **Resource** (things this role actually uses?). One mismatch is a question; three or more is not the owner. The analyzer scored the owner's session 0/5 failed and the second session 5/5.

H2 — Identity → internal resource access

- **ATT&CK:** T1021.002 Remote Services: SMB · T1039 Data from Network Shared Drive · T1133 External Remote Services (gateway).
- **Attacker objective:** turn a cloud identity into access to the internal finance file server.
- **Required permissions:** only what the user already has — RA-gateway access via SSO and read rights on `\\FS-FIN-02\Treasury`. No escalation needed, which is the weakness.
- **Expected authentication events:** gateway tunnel-up for the user; 4624 Type 3 on FS-FIN-02 from the VPN pool; NTLM instead of the user's usual Kerberos.
- **Expected network telemetry:** new flow VPN-pool → FS-FIN-02:445; SMB read volume far above baseline.
- **File-server evidence:** 5145 burst — 412 files in 4 minutes against a baseline of ≤ 25 a day.
- **Detection opportunities:** first-seen (user, server) pair; first-seen (source subnet, server) pair; read-rate threshold; NTLM where Kerberos is normal.
- **Blue-team hunt:** do not ask "did authentication succeed?" (it did, legitimately) — ask "has this identity ever reached this server, from this network, at this rate?"

H3 — Cloud application abuse

- **ATT&CK:** T1098 Account Manipulation (additional access via app grant) · T1528 Steal Application Access Token · T1538 Cloud Service Dashboard · T1114 Email Collection (potential).
- **Attacker objective:** keep access after the session ends by authorising an application.
- **Application permissions:** `Mail.Read` + `offline_access` granted to a disposable lab app ("MailSync Helper").
- **Expected cloud logs:** consent / permission-grant audit event at 10:44 from the suspect session and the second geography; new service principal.
- **Expected API activity:** later non-interactive mail reads from the app's own infrastructure, continuing after session revocation.
- **Detection opportunities:** permission grant from a session already flagged; grant from a non-baseline country; first-seen app with mail scopes.
- **Safe response strategy:** revoke the grant and its refresh tokens, disable the service principal, *then* reset the password — in the lab, delete the disposable app and synthetic identity at exercise end.

Mission 03 — Session-based evasion concept (detection-focused)

Concept — "the borrowed session": the adversary relies entirely on an already-trusted session context and on functions every employee uses: SSO, the remote-access gateway, a file share, an application consent.

Question	Answer
Legitimate functionality abused	Single sign-on session reuse, long session lifetime, remote-access gateway, the user's own file permissions, user-level application consent
Why antivirus sees nothing	No file is written and no process runs on the victim endpoint. The activity happens <i>between the identity provider and the resource</i> . EDR on FIN-LT-22 correctly reports "clean"
Why identity telemetry becomes important	It is the only place the two environments are visible side by side: one identity, two sessions, two devices
What makes the session suspicious	Unregistered device · MFA inherited, not re-proved · unseen app · unseen server · 16× file volume · second country on the same token · alive after sign-out
Cloud logs with evidence	IdP sign-in/session logs (session ID, token ID, device ID, IP), cloud audit (app access, permission grant), app-consent records
Endpoint artifacts that remain	On the <i>owner's</i> laptop: browser history/session store showing only FinLedger, EDR process tree, DNS cache — valuable as negative evidence (the laptop did not make the requests)
Network telemetry that helps	Proxy/DNS (no console request from the laptop), gateway logs (tunnel from an unknown device), firewall/Zeek (VPN pool → FS-FIN-02 SMB, byte counts)
How the blue team detects it	Correlate, per identity: SIEM joins identity logs (new session, token geography) + cloud audit (unseen app, grant) + proxy/DNS (absence on the endpoint) + firewall (new internal flow) + EDR (clean = it is not malware, look at identity)

No session or token theft method is described or used; the lab only models what the defender would observe.

Mission 04 — Identity security lab (concepts demonstrated with the synthetic identity)

Concept	How the lab shows it	Control that closes it
✓ Valid-account abuse	every action succeeds as <code>finance.manager</code> ; zero failed logons	behaviour + device analytics, not failure counts
✓ Session trust	second session accepted with no new proof	token binding to device; continuous access evaluation
✓ MFA limitations	MFA shown as "inherited" on the new session	re-authenticate on new device / sensitive app; phishing-resistant factor
✓ Excessive permissions	a manager can read all of Treasury	least privilege, access reviews
✓ Cloud application permissions	user grants <code>Mail.Read + offline_access</code>	admin-consent workflow, scope restrictions
✓ Shared-account risk	(design note) a shared finance mailbox/login would make owner-vs-attacker impossible to separate	individual identities only
✓ Long-lived sessions	session still refreshing at 19:40, owner out at 18:20	shorter lifetime for finance apps; sign-out revokes all sessions
✓ Inadequate session monitoring	nobody compares cloud events with endpoint requests	identity hunting; "cloud yes / endpoint no" detection
✓ Weak account lifecycle	legacy RA profile without posture check still enabled	joiner-mover-leaver + periodic profile and entitlement review

Safety: every identity is **synthetic + disposable + lab-only**; no real credentials or personal accounts.

 **Senior question — why can identity/session compromise be harder to detect than malware?** Because every individual event is *legitimate by design*. **Legitimate authentication:** nothing fails, so failure-based alerts stay silent. **Trusted applications:** the tools are the corporate SSO, VPN and file share. **MFA status:** logs read "MFA satisfied", which analysts take as reassurance. **User behaviour:** the baseline is fuzzy — people do open new apps — so each anomaly has an innocent explanation. **Endpoint visibility:** EDR watches the laptop, and nothing happens on the laptop. **Cloud visibility:** the evidence sits in IdP and cloud audit logs that are often collected but not hunted, with short retention. **Session duration:** a 24-hour token gives a long, quiet window with no re-check. **Lateral movement:** it uses the user's own entitlements, so it looks like access, not movement. **Data access:** reading files the user is permitted to read raises no access-denied event. Malware has to *do something abnormal on a monitored host*; a borrowed session only has to *do normal things from the wrong place* — and "wrong place" is only visible when identity, device, network and resource logs are joined.

Mission 05 — Blue-team detection challenge

- Which event deserves immediate investigation? 10:39 — the same identity (same token) from another geography** while the 10:02 laptop session is still active. It is the only event with no innocent explanation. 10:31 (412 files) is the highest *impact* and is scoped in parallel.
- Additional identity logs:** all sessions and token IDs for the identity (7–30 days); device IDs and registration state; MFA events and method; conditional-access results; refresh-token issuance; password / MFA-method / recovery changes; gateway authentication.
- Cloud audit logs:** app access by session ID; admin-console views (users, groups, app registrations); **application permission grants and consents**; mailbox rules and forwarding; file-sharing links created; service-principal sign-ins.
- Endpoint evidence to preserve (FIN-LT-22):** EDR telemetry, browser session/history and extension list, DNS cache, proxy client logs, logged-on sessions — as positive *and* negative evidence. Do not reimagine.
- Internal connections:** RA-GW-01 tunnel at 10:07 (device, client IP, pool address 10.50.99.14); pool → FS-FIN-02 SMB; any other destination from that pool address; DC logs for the NTLM authentication.
- Accounts / applications to review:** `finance.manager`; any account used from the unregistered device or pool address; "MailSync Helper" and every app the identity ever consented to; the legacy gateway profile.
- Compromise vs legitimate remote work:**

Evidence	Legitimate remote work	Compromise (observed)
Device	the user's managed laptop or enrolled phone	unregistered device
MFA	fresh challenge on the new device	inherited claim
Sessions	one at a time, or a hand-over	two concurrently, both active
Geography	one place; travel is physically possible	IN and NL on one token, 18 min apart
Endpoint	laptop's proxy/DNS shows the same requests	laptop shows none of them
Behaviour	same apps, normal volume	console + Treasury + 412 files + app grant
User	confirms the activity	denies it (10:51)

- Safe containment:** revoke all sessions and refresh tokens for the identity; disable the "MailSync Helper" grant/service principal; block the second-geography IP and the unregistered device at the gateway; require re-authentication with a phishing-resistant factor from the managed laptop; restrict FS-FIN-02 access for the account while scoping. Reversible, evidence-preserving, and it does not tip off beyond what is unavoidable.

Mission 06 — Identity attack timeline (IST, 08 Oct 2026)

Time	Identity	Device	Source	Destination	Action	Risk	Evidence	Confidence
10:02	finance.manager	FIN-LT-22	198.51.100.22 (IN)	IDP-01	Initial authentication, MFA satisfied	Info	matches 30-day baseline	High
10:07	finance.manager	UNREGISTERED-DEV	198.51.100.50 via RA-GW-01	IDP-01	New session S-1002, token T-B7	Medium	unregistered device; MFA inherited; two environments at once	Medium
10:13	finance.manager	FIN-LT-22	198.51.100.22	FinLedger	Normal application access	Info	proxy record on the laptop matches	High
10:21	finance.manager	UNREGISTERED-DEV	198.51.100.50	Cloud Console	Unseen application (tenant dashboard)	High	never used in baseline; no matching request from the laptop	High
10:26	finance.manager	UNREGISTERED-DEV	10.50.99.14 (VPN pool)	FS-FIN-02	Internal authentication, NTLM Type 3	High	first-seen server for this identity	Medium
10:31	finance.manager	UNREGISTERED-DEV	10.50.99.14	\\FS-FIN-02\Treasury	Sensitive file access ×412	High	16× daily baseline in 4 minutes	High
10:39	finance.manager	UNREGISTERED-DEV	203.0.113.88 (NL)	IDP-01	Geographic anomaly — same token	Critical	one token, two countries, 18 min; owner session still live	High
10:44	finance.manager	UNREGISTERED-DEV	203.0.113.88	MailSync Helper	Application permission change	High	Mail.Read + offline_access granted from the suspect session	High
10:51	finance.manager	FIN-LT-22	help desk	—	User notification: "nothing unusual"	Info	consistent with a clean endpoint	High
19:40	finance.manager	UNREGISTERED-DEV	203.0.113.88	IDP-01	Token refresh after hours	High	owner signed out 18:20; session still alive	Medium

Senior challenge — which event changes "unusual login" into potential identity compromise? **10:39**. Everything before it is *owner-explainable*: a new device (10:07), curiosity about a console (10:21), a file server the user has rights to (10:26), a big download before a deadline (10:31). A token cannot be explained that way — the owner's laptop is still active in India while the same session token is presented from the Netherlands. That moves the question from "is the user behaving oddly?" to "someone else holds the user's session", and it retroactively reclassifies 10:07–10:31 as attacker activity. The analyzer encodes this: remove the 10:39 evidence and the decision drops from CONTAIN to INVESTIGATE (test 12).

Mission 07 — DFIR evidence collection

☒ Authentication logs · ☒ Identity-provider logs · ☒ MFA events · ☒ Session information (session ID, token ID, device ID, IPs) · ☒ Cloud audit logs · ☒ Application-consent records · ☒ Endpoint process telemetry · ☒ Browser security telemetry · ☒ DNS activity · ☒ Proxy logs · ☒ Firewall logs · ☒ Internal authentication logs (DC + FS-FIN-02) · ☒ File-server access logs · ☒ Account changes · ☒ Permission changes · ☒ EDR telemetry

What is lost if the SOC immediately resets the account and reimages the endpoint? - **The live session picture** — which sessions and tokens were active, from which devices and IPs. Revocation without export removes the clearest evidence of the second environment. - **The entry path** — the laptop's browser state, extensions and history are the only way to learn *how* the session context was exposed. Reimaging destroys it, and without the cause the same thing happens again next week. - **Negative evidence** — proof that the laptop did *not* make the console and Treasury requests. That is what clears the user and proves a second actor. - **Volatile data** — memory, DNS cache, open connections. - **Scope certainty** — time-limited IdP/cloud logs may roll over while the team is busy rebuilding. - **And the reset may not even work**: the application grant made at 10:44 survives a password reset, so the attacker keeps mail access while the SOC believes the incident is closed.

Correct order: **preserve** → **revoke sessions/tokens and grants** → **scope** → **then reset and, only if endpoint evidence justifies it, rebuild**.

Mission 08 — Safe adversary simulation (non-destructive, lab only)

Phase	What is done in the lab	Telemetry produced
1	Create a synthetic identity <code>finance.manager</code> in the lab tenant (disposable, no real person)	account-creation audit
2	Authenticate from the approved lab endpoint FIN-LT-22 with the lab MFA	IdP sign-in, MFA event

Phase	What is done in the lab	Telemetry produced
3	Access a normal lab application (FinLedger)	cloud audit, proxy
4	Generate an intentionally unusual pattern: the exercise operator signs in as the same synthetic identity from a second approved lab host placed in a different lab network/region	second session, unregistered device, geography change
5	Read a disposable test repository (\\FS-FIN-02\\Treasury filled with dummy files) at high volume	file-server auth + access burst
6	Let identity + endpoint + network telemetry flow to the lab SIEM; grant a disposable lab app a mail scope	IdP, cloud audit, gateway, firewall, EDR
7	Hand the blue team only the alert "unusual activity for finance.manager" and ask for the timeline	—

The unusual pattern is produced by an *authorised second sign-in with the lab's own credentials* — nothing is stolen, replayed or forged. In this repository the same phases are reproduced as data by `make_session_lab_data.py`.

Success criteria — met by the analyzer output:

Answer	
WHO	finance.manager; session S-1002 assessed NOT THE OWNER, S-1001 TRUSTED
WHERE	UNREGISTERED-DEV via RA-GW-01 (198.51.100.50), then 203.0.113.88 (NL); owner on FIN-LT-22
WHEN	10:07–19:40 IST, 08 Oct 2026
WHAT	Cloud Console, FS-FIN-02 \\Treasury, MailSync Helper
HOW	valid session context, MFA inherited, no password/MFA event, endpoint clean
IMPACT	412 files read on a sensitive share; one mail-scope application grant

Clean-up: delete the synthetic identity, the disposable app and the dummy share; no persistence remains.

 Mission 09 — Defensive architecture: BEFORE vs AFTER hybrid identity security model

BEFORE	AFTER
Long-lived sessions (24 h, never revalidated)	Risk-based session controls: continuous access evaluation, short lifetime for finance apps, sign-out revokes everything
Broad permissions (manager reads all Treasury)	Least privilege + quarterly access reviews; data-owner approval for Treasury
Password + push MFA	Phishing-resistant authentication (FIDO2 / passkeys / certificate), re-proved on new device and sensitive apps
Any device can hold a session	Conditional Access: managed + compliant device required; token bound to the device
Uncontrolled applications (user consent)	Application governance: admin-consent workflow, verified publishers, scope limits, app inventory
Standing admin rights	Privileged Identity Management: just-in-time, approved, time-boxed
Limited identity telemetry, siloed from endpoint	Centralized identity + cloud audit + EDR + network in the SIEM, joined on identity and session
Remote gateway with flat internal reach, legacy profile	Posture-checked access, network segmentation: VPN pool cannot reach Treasury without a second policy
Shared access	Individual identities; no shared logins or mailboxes without named delegation
Weak lifecycle (old profiles, stale entitlements)	Joiner-mover-leaver automation; periodic review of profiles, service accounts and grants
Reactive investigation	Continuous identity hunting: daily "sessions that are not the owner" report

 Senior red-team question — A (obvious malware) vs B (legitimate session abuse)

Dimension	A — malware after endpoint compromise	B — authenticated identity / session abuse
Detection difficulty	Lower: must execute on a monitored host	Higher: each event is valid; needs cross-source correlation
Visibility	Endpoint-rich (process, file, memory, network)	Identity/cloud logs only; endpoint shows nothing
Persistence	Explicit mechanism — detectable, removed by rebuild	Token lifetime + app grants — survives rebuild, sometimes password reset
OPSEC	Noisy; every tool is a signature risk	Quiet; uses the organisation's own SSO, VPN, file share
User trust	User may notice slowness, pop-ups, AV alerts	User notices nothing and sincerely reports "all normal"
Forensic evidence	Abundant and local: binaries, hashes, timelines	Thin and remote: log rows with retention limits; little to image
Lateral movement	Needs credentials/exploits → more noise	Uses existing entitlements across cloud <i>and</i> internal — looks like access
Business impact	Often broader on hosts (ransomware, destruction)	Often deeper on data (mail, finance documents, fraud) with late discovery
Defender response time	Fast playbook: isolate, image, rebuild	Slower: must prove it is not the user, then find every token and grant

Trade-offs, not a winner. A gives the attacker *control of a machine* but pays for it with noise, artifacts and a short clock; defenders have mature tooling and a rehearsed response. B gives *the user's reach* with almost no noise, but only that reach — bounded by the identity's permissions and by the session's lifetime — and it collapses instantly once sessions and grants are revoked, with no implant left to fall back on. A is constrained by endpoint defence; B is constrained by identity governance. An organisation strong in EDR but weak in session and consent control pushes attackers toward B, which is why the lab's biggest gaps are in the identity plane, not on the laptop.

 Mission 10 — Incident closure report

#	Section	Summary (simulated, lab)
01	Initial access	Simulated exposure of an authenticated session context for a synthetic finance identity; root cause in a real case would be established from the laptop's browser evidence
02	Authentication	One genuine sign-in (10:02). Second session (10:07) created with no new password or MFA event — identity <i>used</i> , not re-authenticated
03	Session activity	Unregistered device, inherited MFA, concurrent with the owner, later a second country, alive after hours — 5/5 trust dimensions failed
04	Discovery	Tenant dashboard viewed (users, groups, app registrations) — T1538
05	Internal access	RA-GW-01 tunnel → FS-FIN-02 (NTLM, first-seen) → <code>\Treasury</code> , 412 files
06	Cloud activity	Cloud Console access; application permission grant (<code>Mail.Read + offline_access</code>)
07	DFIR evidence	IdP session/token records, cloud audit, consent record, gateway + firewall logs, 4624/5145 on FS-FIN-02, proxy/DNS + EDR on FIN-LT-22 (negative evidence)
08	Detection	Identity correlation: one token / two countries; cloud-yes-endpoint-no; first-seen server + mass read. EDR and AV correctly saw nothing
09	Containment	Sessions + refresh tokens revoked, app grant removed, device and IP blocked at the gateway, FS-FIN-02 access suspended during scoping, re-enrolment from the managed laptop
10	Remediation	Device-bound tokens + conditional access, phishing-resistant MFA, shorter finance sessions, consent governance, Treasury least privilege, gateway posture + segmentation, identity hunting
11	Business impact	Treasury documents exposed (payment fraud, market-sensitive data), possible mailbox access, regulatory reporting if personal/financial data involved, loss of trust in finance approvals

Detection recommendations: the seven rules in `ghost_session_detections.yml` (six atomic + one 60-minute chain), plus the Zeek hunting notes. **Safe remediation plan:** revoke → remove grants → scope → fix policy → verify with a repeat of the Mission 08 exercise.

 Mission 11 — Incident response decision: ● CONTAIN

Basis	Assessment
Evidence	Five independent anomalies on one session, the strongest (one token, two countries) not owner-explainable
Correlation	Device + Location + Time + Behaviour + Resource all fail for S-1002 and none fail for S-1001 on the same identity, same day
User context	Owner was working normally on the managed laptop, denies the activity, endpoint clean → a second actor
Identity risk	Finance manager: access to Treasury and to mail used for payment approvals; a persistence-capable app grant already made
Resource sensitivity	Treasury share and tenant console are both on the sensitive list; 412 files already read

Monitor would let reading continue and the app grant mature. *Investigate* is right only while every anomaly is still explainable — that ended at 10:39. **Contain now, with reversible identity actions (revoke, block, suspend access), while preserving evidence and continuing to scope.** The cost of a false positive is one user re-authenticating; the cost of waiting is more Treasury data and a foothold in mail.

MITRE ATT&CK map

T1078 Valid Accounts · T1550.004 Web Session Cookie · T1133 External Remote Services · T1538 Cloud Service Dashboard · T1021.002 SMB · T1039 Data from Network Shared Drive · T1098 Account Manipulation · T1528 Steal Application Access Token · T1114 Email Collection (potential)

References: MITRE ATT&CK T1078 / T1098 / T1538 / T1114; Microsoft Learn — Microsoft Entra (conditional access, token protection, continuous access evaluation); SigmaHQ; Zeek documentation. **LAB ONLY** — all data synthetic, no offensive code, no destructive actions.